COMPLIANCE 1 / ASSIGNMENT 2

Compliance Program Development

DeRexi • Financial-services governance • November 3, 2026

> Document status: Draft program design / evidence-based assessment. This is a proposed DeRexi organizational compliance program. It does not assert bank deployment, regulatory certification, implemented secure approvals, or completed employee training.

1. Purpose, scope, and program structure

DeRexi is a policy-governance application being developed for financial-services customers, illustrated by the fictional Aurum Capital Bank. This program defines the accountability, written rules, review procedures, training, and evidence needed to maintain compliance-readiness throughout development and eventual operations.

Scope: DeRexi application administration; staff identity and permissions; policy intake, versioning and clarification; incident assistance; regulatory-awareness updates through Pulse; and software/security changes. GLBA applicability is to be assessed rather than presumed; FFIEC handbook guidance and NIST CSF 2.0 / SP 800-53 inform program design.

Program governance responsibilities

Role / function	Accountability	Required record
Product / Business Owner	Approves program scope, risk acceptance, and major launch decisions.	Signed decision and risk register
Compliance Lead	Owns obligations register, policy reviews, escalation and program status.	Compliance register and review minutes
Security / Technical Lead	Owns control design, testing, fixes and secure change review.	Control test logs and change records
Policy Owners / Data Stewards	Draft and review policies; confirm sources and content ownership.	Review comments and version history
Application Administrator	Manages authorized account lifecycle and role review when implemented.	Access change and review log
Independent Reviewer / Tester	Challenges control evidence and verifies remediation where practicable.	Findings and retest sign-off

Operational cadence

Weekly: triage regulatory alerts, clarifications, and reported security issues. Monthly: review open findings, access-review status, overdue policy revisions, and training exceptions. Quarterly: reassess framework applicability, sample completed controls, and present a program review to the Product Owner. These are proposed cadences, not previously executed meetings.

COMPLIANCE PROGRAM / GOVERNANCE

2. Governance model and communication strategy

Proposed organizational chart

PRODUCT / BUSINESS OWNER — executive accountability

COMPLIANCE LEAD — program owner / escalation point

SECURITY LEAD | APPLICATION ADMIN | POLICY OWNERS

INDEPENDENT REVIEWER — reports findings to Product Owner; separate where feasible

In the student prototype, one developer may temporarily perform multiple functions. The organizational chart describes logical responsibilities rather than actual employees or independent approvals.

Stakeholder identification and reporting

Stakeholder	Information needed	Channel / timing
Product Owner	High-risk failures, unresolved exceptions, scope/budget decisions	Critical issue escalation promptly; monthly summary
Compliance Lead	Agency updates, policy changes, testing and training status	Pulse review queue and weekly register
Security Lead / Admin	Assigned fixes, access incidents and validation evidence	Tracked ticket + evidence link; weekly
Policy Owners	Proposed revisions and clarification requests	In-app clarification / review request; as triggered
Employees / demo personas	Published policy changes, incident instructions, training	Policy library and training module; upon change
Independent reviewer	Complete test evidence and residual risk decisions	Read-only evidence package; at control review

Communication and escalation procedure

1. Intake a signal from Pulse, a policy clarification, a security test, or an incident. 2. Compliance Lead records date, source, impacted process and owner in a register. 3. The owner assesses applicability and drafts a proposed action. 4. Critical control failures move to Security Lead and Product Owner immediately for containment and risk acceptance; noncritical items receive a target date. 5. Closure requires evidence and independent or designated review.

Implementation distinction: Pulse currently displays official-source updates and informational “On the Radar” prompts; it does not assign owners, make legal determinations, or enforce approvals. In-app clarification features exist, but server-side role enforcement was not verified in the November 3 tests.

COMPLIANCE PROGRAM / POLICY

3. Formal Compliance Management Policy

Policy ID: DRX-CMP-001 | Version: 0.1 Draft | Owner: Compliance Lead (proposed) | Approver: Product Owner (proposed) | Effective date: Not yet approved | Review: Annually or upon material change

Purpose and scope

DeRexi shall identify applicable requirements, establish proportionate safeguards, document ownership of policies and records, test control effectiveness, and escalate exceptions. This policy applies to DeRexi development, administration, and personnel who handle internal policy content or customer-related data.

Policy requirements

CM-01 Regulatory register: The Compliance Lead shall keep a source-linked list of relevant laws, guidelines, contractual requirements and review dates; classify external notices as informational until applicability is assessed.

CM-02 Policy lifecycle: Every policy shall have an owner, document ID, version, status, review date, change rationale, and approval record. Drafts shall not be represented as approved without an authorized approval.

CM-03 Access governance: Access shall follow least privilege and be reviewed against job duties. The interface’s role labels are not sufficient evidence of access enforcement; privileged actions require backend controls before deployment.

CM-04 Secure processing: Inputs shall be validated before storage; exceptions must not leak credentials, SQL, or internal server details. Deficiencies shall be assigned an owner and retested.

CM-05 Incident / exception handling: Suspected data exposure, unauthorized policy modification, or failed controls shall be logged and escalated to designated owners with preserved evidence.

CM-06 Training: Staff shall complete onboarding and role-specific policy/security training, with dated knowledge checks and refresher records.

Approval and version-control workflow

Step	Procedure	Evidence
1. Draft	Policy Owner creates or revises a draft with change rationale and relevant obligations.	Draft ID, author, date
2. Review	Compliance Lead checks legal/framework mapping; Security Lead reviews technical effects.	Review notes / change log
3. Approve	Authorized approver signs off; conflicting reviewer/approver duties separated when feasible.	Approval record + timestamp

Step	Procedure	Evidence
4. Publish	Administrator releases approved version and archives prior version.	Version no., effective date, archive link
5. Reassess	Owner reviews at scheduled date or regulatory trigger.	Review log and follow-up

> Current-state limitation: DeRexi includes policy/version data and persona/role models, but the 2026-11-03 isolated tests found backend authentication and role enforcement absent (C-01: 0/15 pass). This policy is a documented requirement, not proof the workflow is technically enforced.

COMPLIANCE PROGRAM / PROCEDURE

4. Detailed procedure: access-control deficiency remediation

Procedure ID: DRX-SOP-AC-001 | Owner: Security / Technical Lead | Trigger: Security assessment or access concern | Associated control: C-01 role-based access control

Objective and inputs

Demonstrate a repeatable method to identify, correct, and retest authorization failures. Inputs: role matrix, API route inventory, test credentials or synthetic test identities, versioned source code, and the baseline security report. No write testing is permitted on the existing non-disposable Supabase project.

Stage	Implementation procedure	Validation / exit criterion
1. Record	Open finding for missing backend auth; rate severity; preserve baseline.	Link to C01-01 through C01-15; owner and due date.
2. Specify	List required access for Employee, Policy Owner and System Admin and any record-level ownership rules.	Reviewed permission matrix and expected 401/403 outcomes.
3. Implement (planned)	Integrate verified identities and server-side authorization; stop using client-side persona choice as proof of permission.	Code changes reviewed; no unapproved Supabase changes.
4. Execute	Use isolated FakeSession and synthetic identities; test no-token, wrong-role and cross-user cases.	Each case has request, expected, actual, result, test file.
5. Remediate	Investigate failures, correct code in development and repeat same tests.	Passing regression tests; failed cases remain open.
6. Review / close	Independent reviewer examines output and validates required behavior and limitations.	Signed closure or documented residual-risk acceptance.

Testing protocol and evidence standard

Run backend/tests/test_security_controls.py from the backend virtual environment after preserving the original run. Required negative tests include anonymous staff-directory access, employee policy approval, cross-user conversations, unauthorized incident updates, and clarification impersonation. Positive tests must verify

legitimate employee questions, policy-owner workflows, and administrator duties remain available. Record code commit, environment, exact commands, test timestamps, HTTP statuses, and sanitized logs.

Actual November 3 baseline (not a retest)

Measure	Result	Disposition
C-01 RBAC	0 passed / 15 failed	Unverified — critical backend enforcement gap
C-02 validation	16 passed / 10 failed	Partially verified — input limits and semantic checks needed
Database enforcement	Not exercised; FakeSession only	Separate approved test database required
JWT verification test	Blocked: PyJWT unavailable in earlier virtualenv	Install and retest only after authorization

The baseline demonstrates application-layer weaknesses, not proof of successful remediation. Approval status: procedure drafted; remediation and post-fix tests pending.

COMPLIANCE PROGRAM / TRAINING

5. Compliance training and assessment plan

Training program ID: DRX-TRN-001 | Owner: Compliance Lead | Status: Designed, not delivered

Audience	Training content / objective	Delivery / frequency
All personnel	Identify policies, recognize confidential data, submit a clarification or report an incident.	20-minute onboarding walkthrough; annual refresher
Employees	Use Policy Assistant responsibly; distinguish cited policy content from generated explanation; avoid sensitive details in questions.	Live demo + practice scenarios
Policy Owners	Review regulatory alerts, evaluate proposed updates, draft and version policies, escalate uncertain obligations.	Workshop and sample review task; on role assignment
Administrators	Least privilege, account lifecycle, evidence logging, backup and incident escalation; why UI gating is insufficient.	Technical walkthrough + checklist; quarterly refresher
Security / Compliance Leads	Assess applicability, classify findings, maintain evidence, approve corrective actions independently where possible.	Case study / tabletop; semiannual

Training session outline and materials

Module 1 (5 minutes): Purpose of DeRexi, scope, and why regulatory awareness differs from legal advice. Module 2 (7 minutes): Find a policy and read its source references. Module 3 (5 minutes): Submit a clarification or incident report and select the appropriate owner. Module 4 (8 minutes): Role permissions, approval process, safe inputs and common risks. Module 5 (5 minutes): Knowledge check and feedback.

Assessment design and passing criteria

Five-question scenario quiz, 80% minimum (4/5). Incorrect answers trigger a short coaching review and retake. A Policy Owner additionally completes a mock policy revision record; an Administrator identifies an unauthorized API request and the expected denial. Assessments use fictional demo content; they do not require writing into the live project database.

Sample assessment questions (answer key included)

Question / prompt	Expected answer
A Pulse article announces a proposed rule. Is it automatically binding on DeRexi?	No. Compliance assesses applicability and status first.
Can an Employee approve an official policy by changing the persona label?	No. Server-side approval permissions are required.
An employee cannot locate the proper policy. What is the next step?	Submit a clarification with the appropriate subject/owner.
A test returns HTTP 200 for anonymous incident data. How should it be handled?	Log a security finding and escalate; do not call the control verified.
What minimum evidence proves training completion?	Participant, date, module/version, assessment result, and reviewer.

Evidence-of-design package

This report provides the training audience matrix, session outline, delivery plan, example assessment items, scoring criteria and recordkeeping design. Actual attendance sheets, completed quizzes, training screenshots and sign-offs are not yet available; they must not be described as delivered training.

COMPLIANCE PROGRAM / IMPLEMENTATION

6. Implementation tracker and rubric crosswalk

Official Assignment 2 requirement	Document location	Readiness
Compliance program structure and operational procedures	Sections 1, 2 and 4	Documented design
Governance model with communication strategy, stakeholders and organizational chart	Section 2	Documented design
Comprehensive policy with approval workflow and version control	Section 3	Draft policy; not yet formally approved
Detailed compliance process with steps, testing protocols and validation	Section 4	SOP documented; execution baseline attached
Training plan: content, delivery, assessment and evidence of design	Section 5	Plan and quiz designed; not delivered

Proposed implementation / ownership schedule

Milestone	Owner	Acceptance evidence
W1 — Confirm policy and governance charter	Product Owner + Compliance Lead	Approval/sign-off on DRX-CMP-001
W2 — Assign compliance process owners and registers	Compliance Lead	Control/obligations register and communication log
W3–4 — Secure backend control remediation	Security Lead	Code review, role matrix and isolated test pass
W5 — Conduct role-specific training pilot	Compliance Lead / Policy Owners	Mock training records and quiz results
W6 — Review risks and close approved actions	Product Owner + reviewer	Signed review and remaining risk register

Reused evidence and document references

1. DeRexi Compliance Assignment 1 — Expanded (October 20, 2026): regulatory applicability, business process mapping, six responsibilities, six-week plan, and controls C-01/C-02.

2. Rubric 1 — Security Control Test Results (November 3, 2026), commit 5d1112a: 41 isolated checks (16 pass, 25 fail), detailed findings F-01 through F-09, test and evidence paths.

3. Pulse Regulatory Intelligence README and Phase 3 notes (November 2, 2026): official-source feed and On the Radar informational categories; no automatic legal obligation review or owner assignment.

4. DeRexi source application / database model: seeded fictional users, departments, role model, policy versions, conversations and clarifications; current application behavior remains subject to security assessment.

> Submission statement: All five Assignment 2 rubric areas are covered at the program-design/documentation level. Approval, operational rollout, delivered training, and post-remediation control verification are not claimed. This report is suitable as a structured proposed program artifact; any instructor requirement for executed governance or training evidence would still require completion.